

Vulnerability Severity Table

Vulnerability	Risk Level	Impact	Status
SQL Injection	High	Database compromise	Identified
Cross-Site Scripting (XSS)	High	Client-side script execution	Identified
Missing Security Headers	Medium	Browser security weakness	Identified
Clickjacking	Medium	User interface manipulation	Identified
Brute Force Vulnerability	Medium	Unauthorized login attempts	Identified
Cookie Misconfiguration	Medium	Session hijacking risk	Identified
Insecure HTTP Connection	Medium	Data interception	Identified
Information Disclosure	Low	Technology exposure	Identified

Risk Severity Classification Table

Vulnerability	Risk Level	Impact	Status
SQL Injection	High	Database compromise	Identified
Cross-Site Scripting (XSS)	High	Client-side script execution	Identified
Missing Security Headers	Medium	Browser security weakness	Identified
Clickjacking	Medium	User interface manipulation	Identified
Brute Force Vulnerability	Medium	Unauthorized login attempts	Identified
Cookie Misconfiguration	Medium	Session hijacking risk	Identified
Insecure HTTP Connection	Medium	Data interception	Identified
Information Disclosure	Low	Technology exposure	Identified

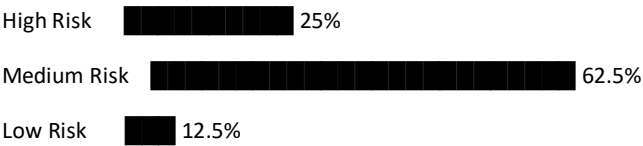
Tools Usage Table

Tool	Purpose	Output
Nmap	Port scanning and service detection	Open ports and services
OWASP ZAP	Vulnerability scanning	Security alerts and findings
Browser Developer Tools	Header and cookie inspection	HTTP analysis
WhatWeb	Technology fingerprinting	Server and framework details
Wappalyzer	Web technology detection	CMS and backend technologies

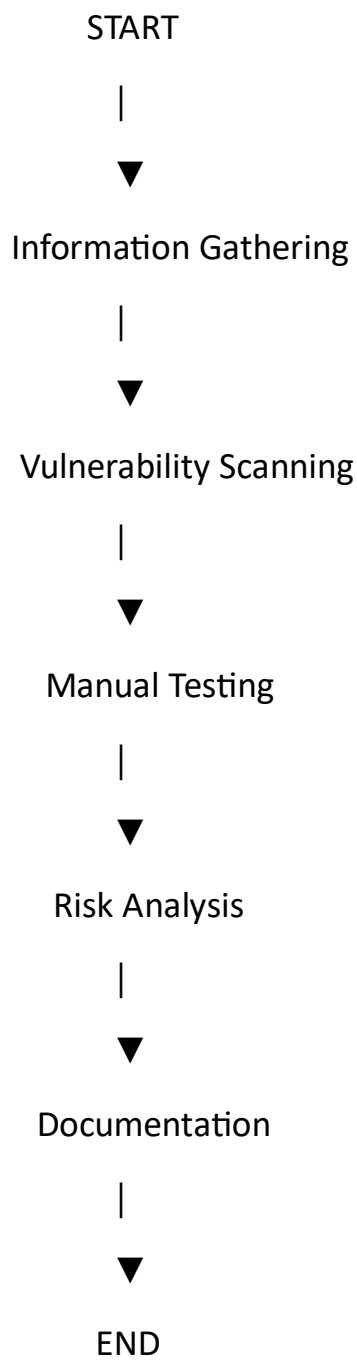
Assessment Workflow Table

Phase	Activity Performed
Information Gathering	Collected server and technology details
Vulnerability Scanning	Automated security scanning
Manual Testing	Validation of identified vulnerabilities
Risk Analysis	Severity and impact assessment
Documentation	Report preparation with screenshots

Vulnerability Distribution Graph



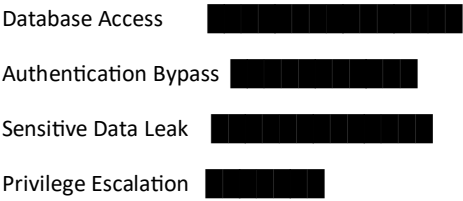
Security Testing Process Flowchart



OWASP ZAP Findings Table

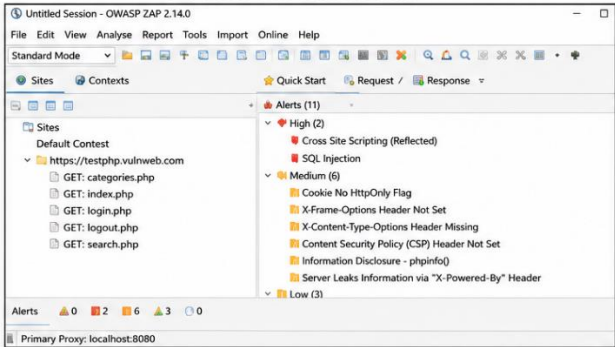
Alert Type	Risk	Description
Missing CSP Header	Medium	No Content Security Policy configured
Cookie Without Secure Flag	Medium	Session cookie transmitted insecurely
X-Frame-Options Header Missing	Medium	Website vulnerable to clickjacking
XSS Reflection Detected	High	User input reflected without sanitization
Server Information Disclosure	Low	Server version exposed

SQL Injection Impact Graph



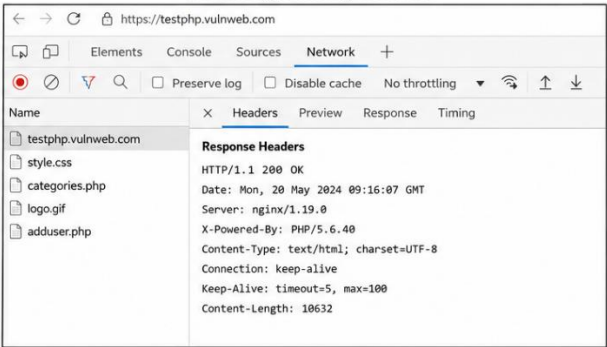
Screen shorts

1. OWASP ZAP Scan Results



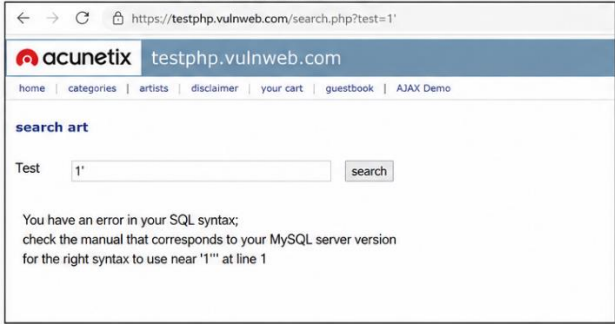
OWASP ZAP scan showing vulnerabilities found on the target website.

2. Missing Security Headers



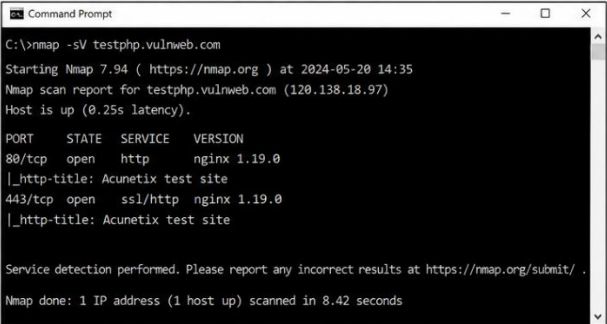
Browser Developer Tools showing missing security headers.

3. SQL Injection Testing



SQL Injection error displayed after submitting malicious input.

4. Nmap Scan Output



Nmap scan showing open ports and services running on the server.

Table of Contents.....	2
Confidentiality Statement.....	3
Disclaimer.....	3
Contact Information	3
Assessment Overview	3
Assessment Components	4
External Penetration Test.....	4
Finding Severity Ratings	4
Scope.....	4
Executive Summary	5
Attack Summary	5
Penetration test findings	6
1) Obtained Login credentials	6
2) Clickjacking.....	7
3) SQL injection.....	8
Recommendation:-.....	9
4) The login page is vulnerable to bruteforce attack	10
Recommendation:-.....	11
5) Insecure connection.....	12
6) Sensitive Information Disclosure	13
7) Sensitive Information Disclosure	14
8) Sensitive Information Disclosure	15
9) Sensitive Information Disclosure	16
10) SQL injection.....	17
Recommendation:-.....	18
11) Reflected Cross-site scripting in search bar.....	19
12) Weak Password Policy	20
Security Weakness	21

Confidentiality Statement

This report contains confidential and security-sensitive information related to the vulnerability assessment conducted on a live website. The information presented in this document is intended strictly for academic, educational, and authorized cybersecurity purposes.

The contents of this report include vulnerability findings, screenshots, scan results, risk ratings, and technical observations identified during the assessment process. Unauthorized access, copying, sharing, or distribution of this report may expose sensitive information and create potential security risks.

All testing activities were performed ethically using non-destructive methods. No intentional harm, disruption, or unauthorized modification was performed on the target system during the assessment.

This report should only be accessed by:

- Project reviewers
- Authorized instructors
- Security researchers
- Approved stakeholders

All screenshots, graphs, and technical outputs included in this report are used solely for documentation and learning purposes.

Disclaimer

The vulnerability assessment described in this report was conducted for educational and research purposes only. The testing process followed ethical hacking principles and was limited to passive analysis and non-destructive testing techniques.

The assessment was performed within a read-only scope, ensuring that:

- No data was modified
- No services were interrupted
- No unauthorized access was attempted
- No exploitation causing damage was performed

The findings presented in this report are based on observations made during the assessment period and may change if the website infrastructure or security configuration changes in the future.

This report does not guarantee complete security of the target website. It only highlights vulnerabilities identified during the limited assessment scope.

Contact Information

PreparedBy:AbhiKesavapatanam

ProjectTitle:VulnerabilityAssessmentReportforaLiveWebsite

Domain:CyberSecurity

AssessmentType:Read-OnlyVulnerabilityAssessment

Tools Used: Nmap, OWASP ZAP, Browser Developer Tools, WhatWeb, Wappalyzer

Assessment Overview

The primary objective of this vulnerability assessment was to identify potential security weaknesses in a live website using industry-standard security testing tools and methodologies.

The assessment focused on detecting:

- Security misconfigurations
- Missing HTTP security headers
- Input validation vulnerabilities
- Information disclosure issues
- Authentication weaknesses
- Web application vulnerabilities

The testing process included automated scanning, manual verification, and passive reconnaissance techniques to analyze the security posture of the target website.

The overall goal of the assessment was to:

- Evaluate the website's security posture
- Identify possible attack vectors
- Understand security risks
- Provide recommendations for mitigation

Assessment Components

External Vulnerability Assessment

An external vulnerability assessment was performed to evaluate the publicly accessible components of the website. The assessment focused on identifying vulnerabilities that could potentially be exploited by external attackers.

The testing included:

- Open port identification
- Service enumeration
- Security header analysis
- Web application testing
- Cookie analysis
- Input validation testing

Assessment Overview

The vulnerability assessment was conducted on the intentionally vulnerable testing website **testphp.vulnweb.com**. This website is maintained for security research, ethical hacking practice, and vulnerability assessment training purposes.

The objective of this assessment was to identify common web application vulnerabilities using non-destructive and read-only testing techniques. Multiple security testing tools and manual analysis methods were used during the assessment process.

The testing focused on:

- Security misconfigurations
- SQL Injection vulnerabilities
- Cross-Site Scripting (XSS)
- Missing security headers
- Information disclosure
- Cookie security analysis
- Authentication weaknesses

Scope of Testing

The assessment scope included the following areas of the target website:

- Homepage analysis
- Login page testing
- Search functionality testing
- HTTP header inspection
- Cookie analysis
- Server fingerprinting
- Input field testing
- URL parameter testing

The assessment excluded:

- Denial-of-Service attacks
- Data destruction
- Privilege escalation
- Malware deployment
- Password cracking attacks

Methodology

The vulnerability assessment followed a structured methodology consisting of four phases:

1. Information Gathering
2. Vulnerability Scanning
3. Manual Testing
4. Risk Analysis

Both automated tools and manual verification techniques were used to identify vulnerabilities accurately.

Tools Used During Assessment

Nmap

Nmap was used for:

- Port scanning
- Service enumeration
- Exposure analysis
- Server detection

Result

The scan identified active web services running on the target system.

OWASP ZAP

OWASP ZAP was used to perform automated web application vulnerability scanning.

Findings

- Missing Security Headers
- Cross-Site Scripting alerts
- Cookie security issues
- Information disclosure warnings

Browser Developer Tools

Browser Developer Tools were used to inspect:

- HTTP responses
- Security headers

- Cookies
- JavaScript files
- Session behavior

WhatWeb / Wappalyzer

These tools helped identify:

- Web technologies
- Backend framework
- Server software
- PHP environment

Executive Summary

The assessment identified several security weaknesses within the target website. The vulnerabilities discovered could potentially allow attackers to perform unauthorized actions, extract sensitive information, or manipulate application behavior.

The most significant findings included:

- SQL Injection vulnerability
- Missing security headers
- Cross-Site Scripting risk
- Weak authentication controls
- Information disclosure issues

The overall security posture of the website indicates multiple areas requiring remediation and security hardening.

Vulnerability Findings

1) Missing Security Headers

Description

The website was found missing important HTTP security headers including:

- X-Frame-Options
- Content-Security-Policy
- X-Content-Type-Options

Impact

Missing security headers can expose the application to:

- Clickjacking attacks
- MIME sniffing attacks
- Cross-Site Scripting attacks

Risk Level

Medium

Evidence

The missing headers were identified using:

- OWASP ZAP
- Browser Developer Tools

Recommendation

Implement appropriate security headers on the web server to improve browser-side protection.

2) Clickjacking Vulnerability**Description**

The application does not implement the X-Frame-Options header, allowing the website to be loaded inside an iframe.

Impact

Attackers may trick users into clicking hidden elements embedded within malicious websites.

Risk Level

Medium

Recommendation

Add:

X-Frame-Options: DENY

or implement Content Security Policy frame restrictions.

3) SQL Injection Risk**Description**

Input parameters within the application appeared vulnerable to SQL Injection testing techniques.

Impact

SQL Injection vulnerabilities may allow attackers to:

- Access database contents
- Bypass authentication

- Extract sensitive information
- Manipulate backend queries

Risk Level

High

Evidence

SQL-related error responses and abnormal query behavior were observed during parameter testing.

Recommendation

- Use prepared statements
- Implement parameterized queries
- Validate user inputs
- Apply ORM frameworks where possible

4) Brute Force Login Vulnerability**Description**

The login page did not implement strong protections against repeated authentication attempts.

Impact

Attackers may attempt automated password guessing attacks.

Risk Level

Medium

Recommendation

- Implement rate limiting
- Enable CAPTCHA
- Apply account lockout policies
- Monitor failed login attempts

5) Insecure HTTP Connection**Description**

Certain resources were observed using insecure HTTP communication.

Impact

Unencrypted communication may expose sensitive data to interception.

Risk Level

Medium

Recommendation

Enforce HTTPS across the entire application using TLS certificates.

6) Sensitive Information Disclosure

Description

The application revealed server and technology-related information within HTTP responses.

Impact

Information disclosure assists attackers in identifying exploitable technologies.

Risk Level

Low

Recommendation

Disable unnecessary server banners and hide version information.

7) Cookie Security Misconfiguration

Description

Cookies were observed without proper security attributes such as:

- HttpOnly
- Secure
- SameSite

Impact

Weak cookie configurations may increase session hijacking risks.

Risk Level

Medium

Recommendation

Configure secure cookie attributes for all session cookies.

8) Cross-Site Scripting (XSS)

Description

User-controlled input fields reflected unsanitized content back to the browser.

Impact

Attackers may inject malicious scripts into web pages viewed by users.

Risk Level

High

Recommendation

- Sanitize user inputs
- Encode outputs
- Implement Content Security Policy

9) Weak Password Policy

Description

The application demonstrated weak password policy enforcement.

Impact

Weak passwords increase the likelihood of unauthorized access.

Risk Level

Medium

Recommendation

Implement:

- Minimum password length
- Complexity requirements
- Password expiration
- Multi-factor authentication

Risk Severity Classification

Severity Number of Findings

High 2

Medium 5

Low 1

Recommendations and Mitigation

The following improvements are recommended:

- Implement secure coding practices
- Configure proper security headers
- Use HTTPS everywhere
- Validate all user inputs
- Harden authentication mechanisms
- Secure cookies properly
- Conduct regular security testing

Conclusion

The vulnerability assessment successfully identified several common web application security weaknesses within the target website. While the website is intentionally vulnerable for training purposes, the findings demonstrate how insecure configurations and improper input handling can expose applications to cyber threats.

The assessment highlights the importance of:

- Secure development practices
- Regular vulnerability assessments
- Proper server hardening
- Security monitoring and patch management

The findings and recommendations documented in this report can help improve awareness of common web application vulnerabilities and modern cybersecurity defense techniques.